Skenario 10

IoT Protocol Guardian

Mengamankan Infrastruktur Backend SmartCow Sprinkler

Proyek PBL Keamanan Siber TEK1314
Kelompok 12 Kelas B SV IPB

Thevan Erlangga (J0404241073)
Lead & Purple Team Coordinator

Muhamad Akhdan Ramadhan (J0404241102)
Red Team (Offensive Security)

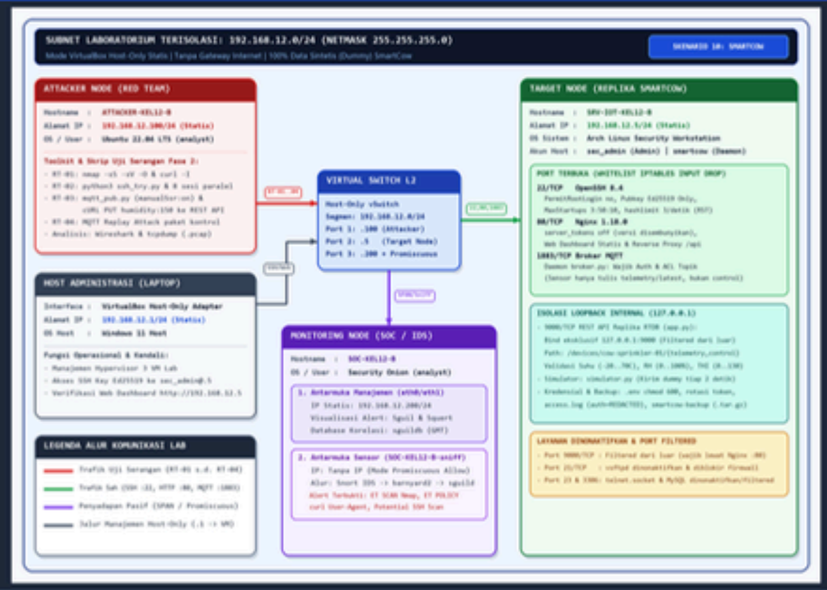
Fachri Abyasa Tarid (J0404241136)
Blue Team (Defensive & Hardening)

LINGKUNGAN UJI	Subnet VirtualBox Host-Only **192.168.12.0/24** dengan 100% data telemetri sintetis (dummy)

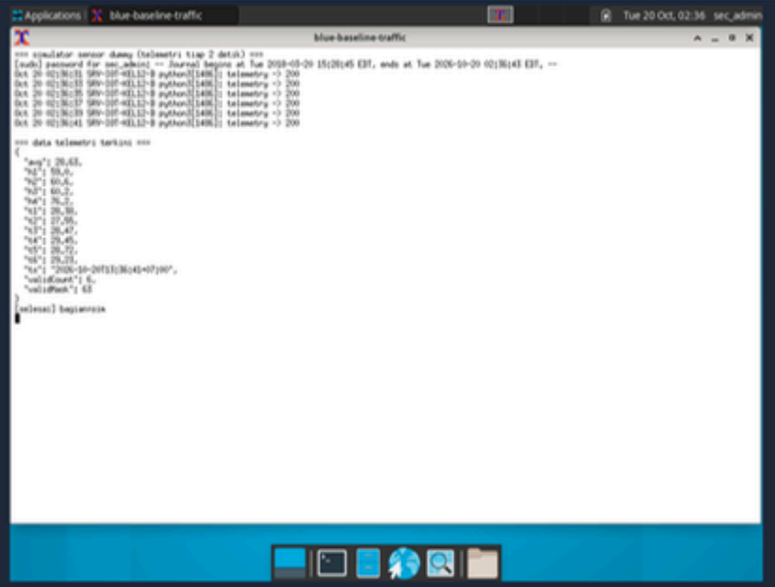
ARSITEKTUR & BUKTI REPLIKA LAB SMARTCOW

Repositori: github.com/SwipeLz/TEK1314-2026-Kel-12-Kelas-B

1. TOPOLOGI LAB TERISOLASI (192.168.12.0/24 - HOST-ONLY)

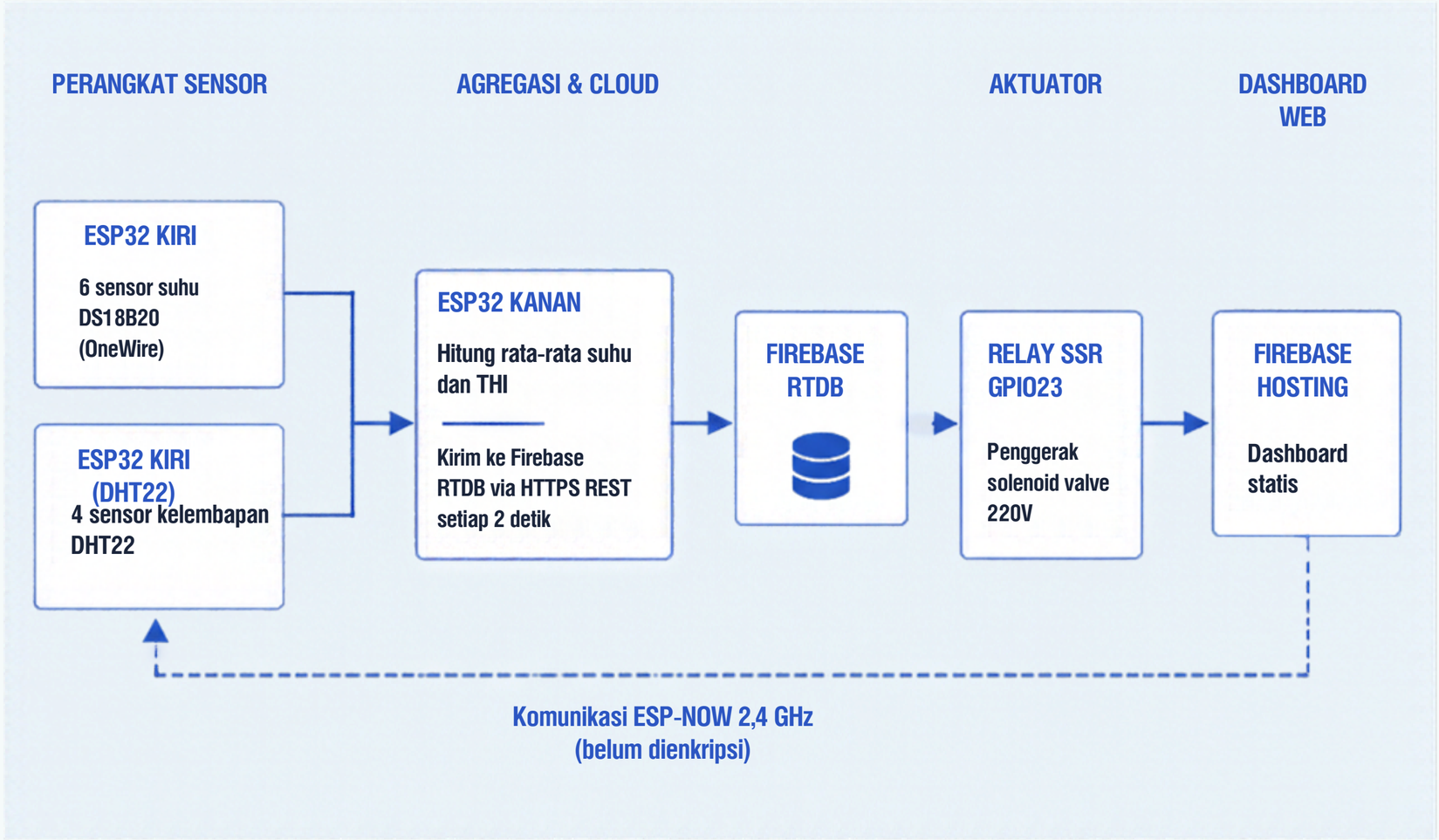


2. BASELINE TELEMETRI SIMULATOR (simulator.py -> 127.0.0.1:9000)



Konteks Proyek IoT SmartCow & Identifikasi Celah Asli

Arsitektur asli sistem dan tiga celah keamanan kritis pada firmware ESP32



TIGA CELAH KEAMANAN KRITIS PADA FIRMWARE ESP32

01

HARD-CODED SECRET

Parameter ?auth= tertanam langsung di esp32/src/main.cpp, rawan diekstraksi

02

TLS TIDAK AMAN

Metode setInsecure() menonaktifkan validasi sertifikat TLS

03

KOMUNIKASI NIRKABEL TIDAK AMAN

Komunikasi ESP-NOW 2,4 GHz belum dienkripsi

Deklarasi Tech Stack

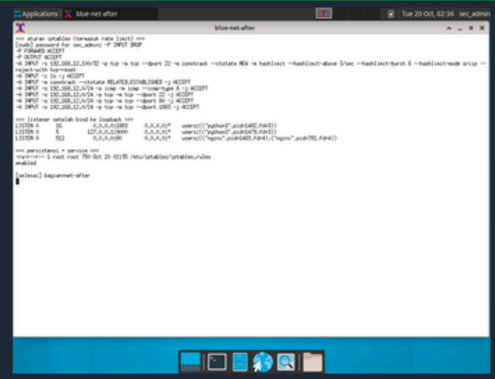
Pemetaan komponen arsitektur produksi Google Firebase
ke lingkungan replika mandiri berbasis Arch Linux dan Python 3.9 di laboratorium

SISTEM PRODUKSI GOOGLE FIREBASE	REPLIKA LABORATORIUM ARCH LINUX
Backend Server OS Serverless Google Firebase	**Arch Linux Security Workstation** SRV-IOT-KEL12-B (192.168.12.5) systemd user smartcow
Penyimpanan Data Firebase RTDB devices/cow-sprinkler-01/...	**Penyimpanan JSON Lokal** endpoint REST 127.0.0.1:9000 app.py
Protokol Telemetri HTTPS REST Database Secret	**HTTP REST + Token Bearer** simulator.py tiap 2 detik
Dashboard & Gateway Firebase Hosting	**Nginx 1.18.0 Port 80** reverse proxy /api ke loopback port 9000
Otorisasi & Broker MQTT Firebase Auth/Rules	**Token Bearer API** daemon broker.py port 1883 berautentikasi dan ACL topik

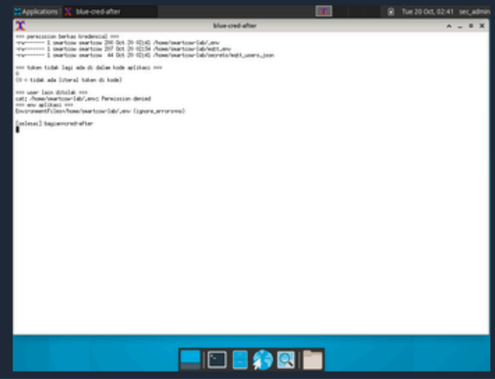
BUKTI LAYANAN REPLIKA LAB

SRV-IOT-KEL12-B (192.168.12.5)

A. LISTENER LOOPBACK (ss -lntp)



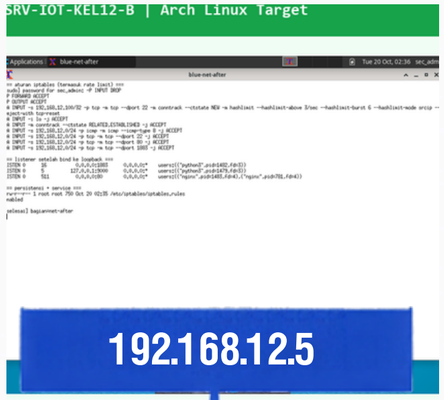
B. PROTEKSI KREDENSIAL (.env 600)

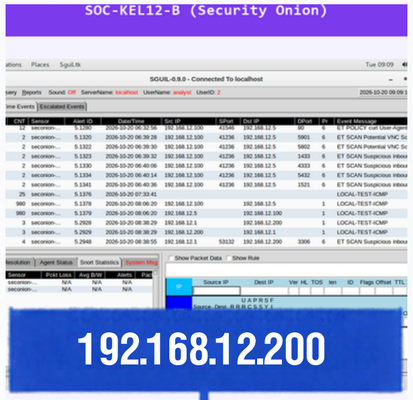


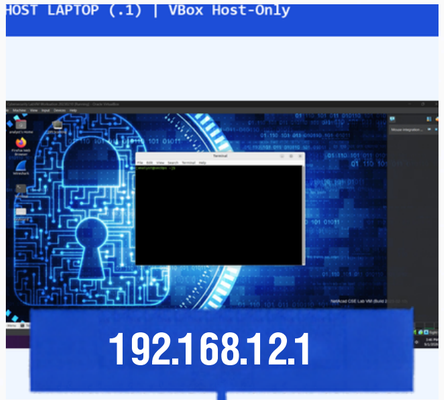
Topologi Jaringan & Skema Pengalamatan IP

(192.168.12.0/24)









SUBNET TERISOLASI: 192.168.12.0/24

ATTACKER NODE

Ubuntu 22.04 LTS
ATTACKER-KEL12-B (analyst)

nmap, Wireshark, tcpdump, cURL,
ssh_try.py, mqtt_pub.py

TARGET NODE

Arch Linux
SRV-IOT-KEL12-B (sec_admin)

OpenSSH (22)
Nginx (80)
Broker MQTT (1883)
API loopback (127.0.0.1:9000)

MONITORING NODE

Security Onion
SOC-KEL12-B

NIC manajemen Sguil/Squert
NIC sensor promiscuous
(SOC-KEL12-B-sniff) tanpa IP

HOST ADMIN NODE

Laptop Windows
VirtualBox Host-Only Adapter

Manajemen hypervisor
Kunci SSH Ed25519
Uji dashboard web

Progres Hardening Blue Team

9 kontrol keamanan diimplementasikan dan **100%** selesai

KONTROL KEAMANAN

9

STATUS

100%

SELESAI

ACCESS & AUTH (A1-A3)

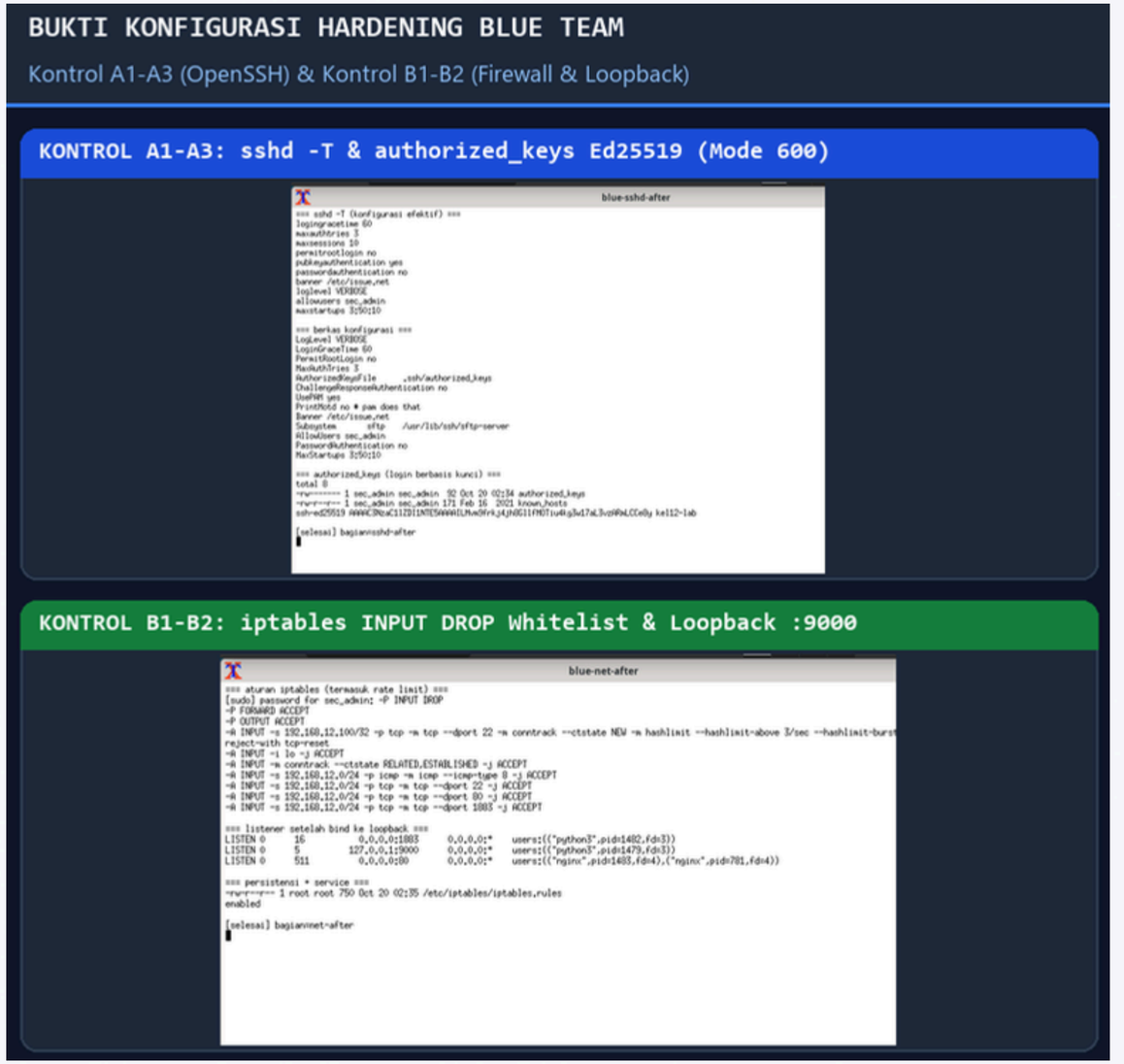
PermitRootLogin no, wajib kunci Ed25519 (PasswordAuthentication no), MaxStartups 3:50:10 & hashlimit 3/detik.

ATTACK SURFACE (B1-B3)

Firewall iptables INPUT DROP whitelist (22, 80, 1883) persisten, isolasi API di 127.0.0.1:9000, & server_tokens off.

DATA & APPLICATION (C1-C3)

Validasi rentang suhu/RH & ACL topik MQTT, izin .env 600 (user smartcow), log auth=REDACTED, & smartcow-backup.



Matriks Verifikasi Teknis

Perbandingan kondisi sebelum dan sesudah hardening pada 9 kontrol keamanan di Target Node

SEBELUM HARDENING	KONTROL KEAMANAN	SESUDAH HARDENING
Login sandi terbuka tanpa batas Root dapat digunakan Tanpa pembatasan koneksi	**A1-A3** **Access & Auth**	**Root ditolak** Wajib kunci Ed25519 MaxStartups 3:50:10 Hashlimit 3/detik
Firewall kosong API bind 0.0.0.0:9000 Header nginx/1.18.0 terekspos	**B1-B3** **Attack Surface**	**INPUT DROP persisten** Bind 127.0.0.1 Server: nginx
Kelembapan 150% diterima (HTTP 200) Publish MQTT anonim	**C1** **Validasi Input & ACL**	**HTTP 400 Bad Request** CONNACK 5 Blokir ACL
.env mode 644 Token hardcoded di app.py Backup belum teruji	**C2-C3** **Secrets & Recovery**	**Chmod 600** Rotasi token Log auth=REDACTED Uji restore backup berhasil

BUKTI VERIFIKASI HARDENING

Before (Vulnerable) vs After (Hardened)

SEBELUM: Login Sandi Berhasil



SESUDAH: Permission Denied (Pubkey)



SESUDAH: Injeksi 150% Ditolak (400)



Rencana & Eksekusi Serangan Red Team Fase 2 (RT-01 s.d. RT-04)

Empat skenario uji terarah dan bukti permukaan serangan awal

PARAMETER BASELINE

Source 192.168.12.100 ke Target 192.168.12.5

Ping 0% packet loss (RTT avg 1,202 ms)

Port awal terbuka: 22, 80, 1883, dan 9000

RT-01

RECONNAISSANCE

Pemindaian port dan banner layanan via nmap -sS -sV -O -p 22,80,1883,9000 192.168.12.5

serta
curl -I http://192.168.12.5/

RT-02

EXPLOITATION & ACCESS

Uji kredensial SSH berulang via python3 ssh_try.py (root & sec_admin)

Peluncuran 8 sesi koneksi SSH paralel serentak

RT-03

WEB & PROTOKOL IOT

Publish tanpa izin via mqtt_pub.py ke cow-sprinkler-01/control ('{"manualSsr":"on"}')

cURL PUT kelembapan 150% ke REST API

RT-04

REPLAY ATTACK

Perekaman paket kontrol pompa yang sah

Dikirimkan ulang (replay) ke broker 192.168.12.5:1883 saat jadwal penyiraman idle

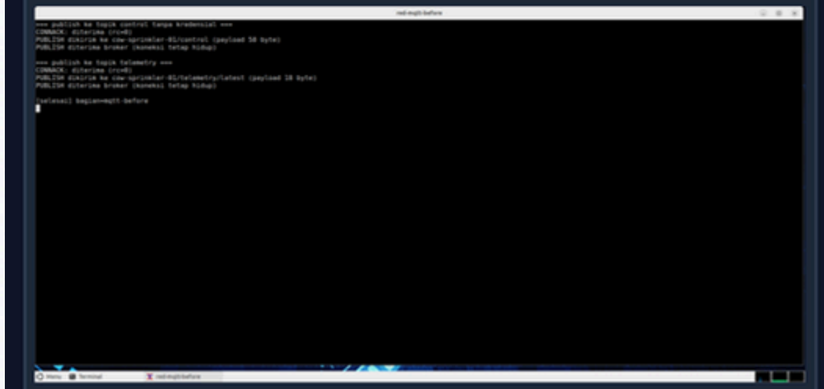
BUKTI EKSEKUSI RED TEAM

Pengujian dari ATTACKER-KEL12-B (.100)

RT-01: Pemindaian Nmap Awal (Port Terbuka)



RT-03: Publish MQTT & Injeksi REST API



Evaluasi Purple Team Loop, Deteksi Sguil & Kendala Lab

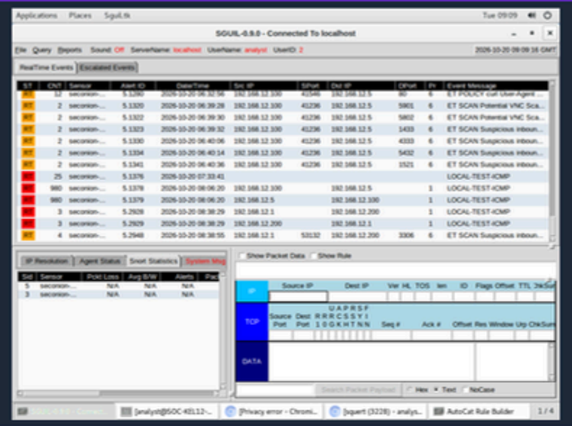
Ringkasan siklus 5 tahap, deteksi IDS Snort/Sguil, dan penanganan kendala lab

TAHAP 1	TAHAP 2	TAHAP 3	TAHAP 4	TAHAP 5
SEBELUM HARDENING	IDENTIFIKASI	EKSPLOITASI	ANALISIS & RESPONS	SESUDAH HARDENING
Port 9000 terbuka dari luar Login SSH sandi berhasil Injeksi kelembapan 150% diterima (HTTP 200) Publish MQTT anonim menembus broker	Pengumpulan informasi aset Enumerasi layanan dan celah Validasi temuan awal	Uji akses tidak sah ke backend Uji injeksi data sensor Uji publish MQTT anonim	Analisis log & alert IDS Triase dan Klasifikasi risiko Rekomendasi perbaikan	Port 9000 filtered Login sandi ditolak (Permission denied publickey) Kelembapan 150% ditolak (HTTP 400) MQTT anonim ditolak (CONNACK 5)
DETEKSI SGUIL 06:30-06:47 GMT 13:30-13:47 WIB	ET SCAN Nmap Scripting Engine	ET POLICY CURL User-Agent (:80)	ET SCAN Potential SSH Scan (22)	
SOLUSI KENDALA LAB	Mengaktifkan IDS ENGINE_ENABLED=yes & mode promiscuous	Membangun modul Python 3.9 mandiri tanpa internet	Mengaktifkan iptables service	

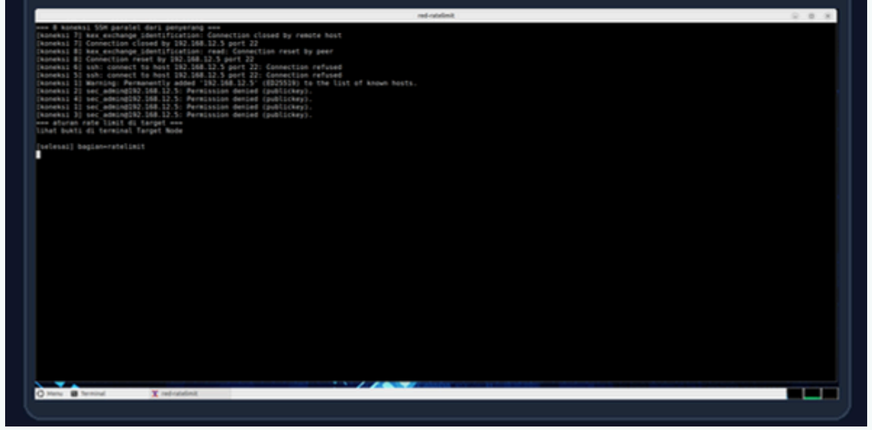
DETEKSI SGUIL & VERIFIKASI TAHAP 5

SOC-KEL12-B (.200) & Target (.5)

DETEKSI IDS: Alert Sguil Escalated Events



TAHAP 5: Koneksi Paralel Diredam Firewall



Rekomendasi Sistem Produksi & Catatan Pengumpulan GitHub

01

MITIGASI PRODUKSI 1 & 2

Cabut Database Secret dari esp32/src/main.cpp
Ganti dengan token berbatas waktu
Hapus setInsecure() dan sematkan sertifikat Root CA Firebase

02

MITIGASI PRODUKSI 3 & 4

Aktifkan enkripsi PMK/LMK AES-128
pada kanal nirkabel ESP-NOW 2,4 GHz
Terapkan validasi rentang sensor dan ACL topik MQTT

03

KEPATUHAN STRUKTUR GITHUB

Pertahankan utuh docs/design/topology.png & ip_plan.md dari Minggu 4
Lengkapi docs/blueteam/, docs/redteam/,
dan docs/purple-team-log.md

04

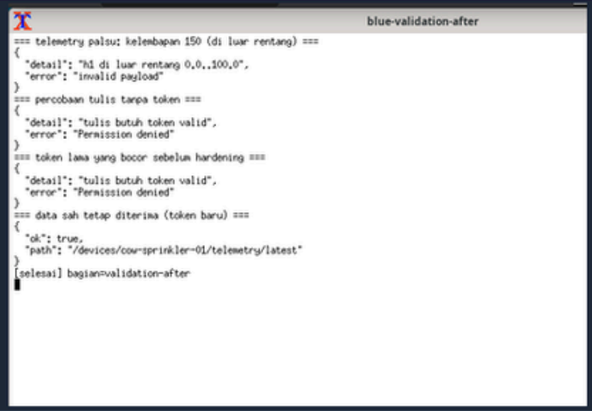
INSTRUKSI UNGGAH WAJIB

Ekspor presentasi ini ke format PDF
dan unggah ke docs/presentation-minggu9/slides.pdf
sebelum sesi praktikum Minggu ke-9 dimulai

BUKTI VALIDASI INPUT API & PROTEKSI WEB

Kontrol C1 (Validasi Rentang & Token) & Kontrol B3 (Server Tokens)

KONTROL C1: Tolak Kelembapan 150% & Token Lama (blue-validation-after)



KONTROL B3: Header Server: nginx & server_tokens off (blue-nginx-after)

